

문서 버전: v1.6.0-ENTERPRISE

작성일자: 2026년 8월 11일

대상 사용자: 시스템 관리자,
Security/DevOps

구분: 공식 엔터프라이즈 문서

- 문서 버전: v1.6.0-ENTERPRISE
- 작성일자: 2026년 8월 11일
- 대상: 시스템 관리자, Security & Infrastructure 엔지니어, CISO, DBA
- 문서 개요: Relio 단일 컨테이너 부트스트랩, Keycloak OIDC SSO, Break Glass 계정, Master Key 봉인 영속성, HMAC Key 회전, Command Center 및 감사 로그 운영

1. 시스템 부트스트랩 및 환경변수 명세 (Bootstrap Specification)

Relio는 사내 폐쇄망(Air-gapped) 환경에서 **3개의 필수 환경변수**만으로 시스템 부트스트랩을 완료합니다. 자격증명 영속성을 위해 **선택 환경변수 1개**를 추가할 수 있습니다.

```
# 필수 환경변수 3개
POSTGRES_DSN=postgres://relio:Secr3tPass123@10.10.50.5:5432/relio?sslmode=disable
BOOTSTRAP_ADMIN=admin
BOOTSTRAP_ADMIN_PASSWORD=SuperAdminPassword2026!

# 선택 환경변수 1개 (자격증명 영속성 보장)
# openssl rand -hex 32 로 최초 1회 생성 후 비밀번호 관리 도구에 보존
ENCRYPTION_KEY=3f9c1d8e2a4b7f90e...64자리16진수
```

ENCRYPTION_KEY 권장 이유:

ENCRYPTION_KEY 를 지정하지 않으면 SSO Client Secret 및 API Key를 암호화하는 Master Key가 /var/lib/relio/secrets/master.key 파일로만 존재합니다. 컨테이너 Volume이 재생성되면 기존 암호

호화 데이터를 복구할 수 없습니다. `ENCRYPTION_KEY` 를 주입하면 Volume을 완전히 새로 생성하거나 컨테이너를 이관해도 동일 키로 자격증명이 완전하게 복원됩니다.

Break Glass 계정 원칙:

`BOOTSTRAP_ADMIN` 계정은 시스템 최초 기동 시 DB에 계정이 없을 때만 자동 생성되는 비상 수퍼관리자 계정입니다. 1회 생성 후 환경변수를 다르게 지정하더라도 기존 비밀번호나 계정을 덮어쓰지 않으므로 안심하고 운영할 수 있습니다.

2. 볼륨 마운트 및 Master Key 무결성 검증 (`/var/lib/relio`)

2.1 컨테이너 실행 명령

```
docker run -d \
  --name relio \
  -p 8080:8080 \
  -e POSTGRES_DSN="postgres://relio:password@postgres:5432/relio" \
  -e BOOTSTRAP_ADMIN="admin" \
  -e BOOTSTRAP_ADMIN_PASSWORD="StrongAdminPassword123!" \
  -e ENCRYPTION_KEY="$ENCRYPTION_KEY" \
  -v relio-data:/var/lib/relio \
  relio:v1.6.0
```

2.2 Master Key와 DB 연속성 검증 (Fail-Closed)

Relio는 Master Key 원문 대신 단방향 12자리 식별자(Key ID)를 계산하여 PostgreSQL의 `master_keys` 테이블에 등록합니다. 만약 DB에 활성 자격증명이 존재하는데 올바르지 않은 `ENCRYPTION_KEY` 또는 비어있는 Volume이 연결되면 어플리케이션은 새 키를 생성하지 않고 `instance encryption key integrity check failed` 오류와 함께 기동을 멈추어 데이터 손상을 방지합니다.

3. Operations Command Center & 진단 7종 (/admin/operations)

운영 관리자는 Operations Command Center에서 7대 핵심 요소에 대해 자동 상태 진단을 수행합니다.

1. **PostgreSQL Connection:** DB 연결 응답 속도 및 커넥션 풀 유효성.
2. **Database Schema Migration:** embed SQL 마이그레이션 적용 및 버전 무결성.
3. **Master Key Protection:** Envelope Key 봉인 상태 (`ENCRYPTION_KEY` 활성화 여부).
4. **Storage Access:** `/var/lib/relio` 디렉토리 쓰기 권한 검사.
5. **OIDC Provider Health:** Keycloak Issuer Discovery 및 JWKS 엔드포인트 응답성.
6. **REST API & MCP Readiness:** `/api/v1` 및 `/mcp` 어댑터 가용성.
7. **Background Job Loop:** 일별 Forecast Snapshot 및 유예기간 만료 런너 동작 여부.

4. Keycloak OIDC SSO 및 3중 권한 교집합 (RBAC & Data Scope)

4.1 Keycloak OIDC 설정 (/admin/security/oidc)

- **Issuer URL:** `https://sso.company.internal/realms/enterprise`
- **Client ID:** `relio-crm`
- **Client Secret:** `.....`
- **Redirect URI:** `https://relio.company.internal/api/v1/auth/oidc/callback`

4.2 3중 권한 교집합 적용 (Triple Intersection Authorization)

Relio는 사용자 요청 시 **Function Permission**(기능 권한) $\cap$ **Data Scope**(SELF/TEAM/ALL) $\cap$ **Personal Key Scope**의 교집합만을 엄격하게 허용합니다.

5. Personal API Key HMAC Digest & 7일 Grace Period 회전

- **HMAC Digest 저장:** Raw Key는 DB에 보관되지 않으며 **HMAC-SHA256** Digest만을 저장하여 DB 유출 시에도 안전합니다.
- **7일 Grace Period 무중단 회전:** 키 회전(Rotate) 수행 시 기존 키는 7일간 Dual-Active 상태로 유지되어 서비스 중단 없이 시스템 키를 교체할 수 있습니다.

6. Configuration Bundle Diff & Non-Destructive Upsert

(**/admin/system/config-bundle**)

- **Configuration Export:** Pipeline, Playbook, Exit Criteria, Coaching Rule, 승인 정책 등 시스템 설정을 JSON으로 묶어 Export합니다.
- **Diff & Non-Destructive Upsert:** Import 시 현재 환경과의 차이점을 **CREATE** / **UPDATE** / **NO_CHANGE** 로 진단하고 확인 후 비파괴 Upsert로 안전하게 반영합니다.

7. Audit Trail 및 DB 백업 절차

- **Audit Log (**/admin/audit**):** OIDC 설정 변경, 파이프라인 수정, 승인 처리 등 모든 관리자 액션을 사용자 ID, IP, 시각, 변경 전후 DTO Snapshot과 함께 보존합니다.
- **DB 백업 명령:**

```
pg_dump -U relio -h 10.10.50.5 relio | gzip > /backup/relio_db_$(date +%Y%m%d).sql.gz
```